

LAB 01: INCIDENT RESPONSE & DIGITAL FORENSICS

Technical Incident Response Report · GitHub Portfolio Edition

Report ID	IR-2026-LAB01
Target System	AWS EC2 Instance — Ubuntu 22.04 LTS — ip-172-31-42-76
Severity	High / Critical
Analyst / Role	Junior SOC Analyst / DFIR Responder
Status	Remediated / Closed
Date	6 August 2026

1. Executive Summary

Suspicious processes and system anomalies were identified on the target AWS EC2 server, initiating a full Incident Response and Digital Forensics (DFIR) investigation.

The investigation determined that an attacker from 198.51.100.45 obtained the password for the `app_deployer` account through SSH brute-force activity. After gaining access, the attacker escalated to root privileges, executed a Python-based bind shell from `/tmp/.sys_update` listening on TCP port 4444, and established persistence through a SUID backdoor, malicious cron job, and unauthorized SSH public key. The attacker also archived `/etc/passwd` and `/etc/shadow` in preparation for exfiltration.

Outcome: All identified threat components were isolated and removed. The compromised account was locked, and post-remediation checks verified removal of the identified persistence and command-and-control artifacts.

2. MITRE ATT&CK® Mapping

Tactic	Technique	ID	Evidence
Initial Access	Valid Accounts / SSH	T1078	<code>app_deployer</code> password used from 198.51.100.45
Privilege Escalation	Setuid / Setgid	T1548.001	SUID-root <code>/var/tmp/.systemd-helper</code> (4755)
Persistence	Scheduled Task: Cron	T1053.003	<code>/etc/cron.d/systemd-check</code>
Persistence	Account Credentials: SSH Keys	T1098.004	Attacker key added to <code>authorized_keys</code>
Defense Evasion	Masquerading / Hidden Files	T1036	Hidden-name payload at <code>/tmp/.sys_update</code>

Command & Control	Non-Standard Port	T1571	Listener on TCP/4444
Collection / Exfiltration	Archive Collected Data	T1560	/var/tmp/.sys_config_bak.tar.gz

3. Investigation Scope and Sources

- **Operating system:** Ubuntu Linux on AWS EC2
- **Log sources:** /var/log/auth.log, journalctl / sshd
- **Network and process tools:** netstat, ps, /proc
- **File-system tools:** find, ls, cat

4. Forensic Analysis and Findings

4.1 Network and Port Triage

```
sudo netstat -tulpn

tcp  0  0  0.0.0.0:4444  0.0.0.0:*  LISTEN  3723/.sys_update
tcp  0  0  127.0.0.53:53  0.0.0.0:*  LISTEN  349/systemd-resolve
tcp  0  0  0.0.0.0:22    0.0.0.0:*  LISTEN  1/init
```

Finding: A hidden-name process, `.sys_update`, associated with PID 3723 was listening on TCP/4444 bound to 0.0.0.0, exposing it through every network interface.

4.2 Process and Executable Analysis

```
ps aux | grep 3723
sudo ls -l /proc/3723/exe

root  3723  ... /tmp/.sys_update -c import socket,time; s=socket.socket(); s.bind(('0.0.0.0',
4444)); s.listen(5); ...
lrwxrwxrwx  ... /proc/3723/exe -> /tmp/.sys_update
```

Finding: The process was running as root. A Python executable was placed in `/tmp` under a hidden filename and was used to create a socket listener.

4.3 Initial Access Verification

```
sudo journalctl -t sshd -n 20

Aug 06 06:36:18 ... Failed password for invalid user admin from 198.51.100.45 ...
Aug 06 06:36:18 ... Failed password for app_deployer from 198.51.100.45 ...
Aug 06 06:36:18 ... Accepted password for app_deployer from 198.51.100.45 ...
```

Finding: The successful password-based SSH login followed failed attempts in the same second. The suspicious process start time also aligned with this authentication event.

4.4 Persistence, Privilege Escalation, and Data Staging

```
sudo find /tmp /var/tmp -type f -perm -4000 -ls
sudo cat /home/app_deployer/.ssh/authorized_keys
sudo cat /etc/cron.d/systemd-check
sudo ls -la /var/tmp
```

Component	Evidence	Assessment
SUID backdoor	/var/tmp/.systemd-helper -rwsr-xr-x, root-owned	The SUID bit can cause an executable to run with the effective privileges of its owner (root).
SSH key backdoor	/home/app_deployer/.ssh/ authorized_keys attacker@evil-c2.com	Provides a persistence path for key-based SSH access even if the password is changed.
Cron persistence	* * * * * root /var/tmp/.sys_update >/dev/null 2>&1	Attempts to relaunch the malicious component as root every minute.
Data staging	/var/tmp/.sys_config_bak.tar.gz	Prepared /etc/passwd and /etc/shadow for potential exfiltration.

5. Containment and Eradication

Incident-response principle: Evidence should normally be preserved before destructive actions, with authorization and escalation handled under the organization’s incident-response procedure. In this controlled lab, the process was terminated and the identified artifacts were removed.

```
# 1. Stop active C2 / malicious process
sudo kill -9 3723

# 2. Remove persistence mechanisms
sudo rm -f /etc/cron.d/systemd-check
sudo rm -f /home/app_deployer/.ssh/authorized_keys

# 3. Remove malicious files and staging archive
sudo rm -f /tmp/.sys_update
sudo rm -f /var/tmp/.systemd-helper
sudo rm -f /var/tmp/.sys_config_bak.tar.gz

# 4. Lock compromised account
sudo passwd -l app_deployer
```

6. Post-Remediation Verification

```
sudo netstat -tulpn | grep 4444
# No output: the TCP/4444 listener is closed

sudo ls -la /tmp/.sys_update /var/tmp/.systemd-helper /etc/cron.d/systemd-check 2>&1
# No such file or directory: artifacts are absent
```

Verification Result: The TCP/4444 listener was no longer present, and the investigated malicious process, files, and cron entry could not be found.

7. Hardening Recommendations

1. **Disable SSH password authentication:** Configure `PasswordAuthentication no` in `sshd_config` and allow only managed SSH keys.
2. **Enable Fail2Ban:** Detect repeated failed SSH attempts and apply temporary network-level bans.
3. **Harden temporary directories:** Where architecture permits, evaluate `noexec` and `nosuid` mount options for `/tmp` and `/var/tmp`, after application compatibility testing.
4. **Apply least privilege:** Restrict sudo permissions for deployment and service accounts; regularly review account, password, and SSH-key lifecycle.
5. **Improve visibility:** Centrally collect SSH, sudo, user/group, and critical-file change telemetry, then define actionable detections.

This document is a technical incident-response report produced in a controlled educational laboratory. A production investigation should extend these steps with evidence preservation, scoping, authorization, communications, and formal recovery processes.